

Audit et Sécurité Informatique

Audit et Sécurité Informatique

1. Introduction et Objectifs

2. Méthodologie de Veille et Outils de Contrôle

3. Analyse de la Robustesse : Tests d'Intrusion

4. Communication et Récurrence de Confiance

Conclusion

1. Introduction et Objectifs

L'enjeu de ces missions était d'assurer l'intégrité numérique d'une infrastructure (type M@Banque) en combinant une surveillance active des menaces et des tests de robustesse concrets. L'objectif est double : identifier les vulnérabilités système et restaurer la confiance des utilisateurs par une communication transparente.

2. Méthodologie de Veille et Outils de Contrôle

Pour rester efficace, l'audit doit s'appuyer sur une veille technologique structurée permettant de sélectionner les meilleurs outils:

Veille documentaire : Utilisation de Google Alerts et Feedly pour capturer et filtrer les informations pertinentes sur les nouvelles failles.

Curation et Partage : Centralisation des connaissances via Scoop.it et diffusion rapide des alertes à l'équipe technique via Slack.

Outils d'audit web : Identification de Burp Suite pour l'analyse du trafic applicatif et de Nessus pour la détection des failles d'infrastructure.

3. Analyse de la Robustesse : Tests d'Intrusion

La sécurité dépend directement de la politique de gestion des accès. Des tests ont été menés sur une machine Windows 10 pour éprouver différents niveaux de complexité de mots de passe:

Extraction des données : Récupération des empreintes numériques (hashs) via l'outil FGDUMP.

Vulnérabilités constatées : * Les mots de passe simples (ex: "judo63") sont craqués instantanément par des attaques contextuelles.

Les mots de passe basés sur des noms communs (ex: "aurillac15") ne résistent pas aux attaques par dictionnaire (*rockyou.txt*).

L'outil Ophcrack a démontré que la longueur ne suffit pas si le mot de passe reste purement alphanumérique, à cause de l'efficacité des *Rainbow Tables*.

Sécurité renforcée : Seul le compte avec un mot de passe complexe (mélange de caractères spéciaux, majuscules, chiffres) a résisté aux tentatives de force brute dans le temps imparti.

4. Communication et Récurrence de Confiance

En cas d'incident, l'aspect technique doit être complété par une action de réassurance auprès des clients:

Transparence : Inciter les utilisateurs à vérifier eux-mêmes la sécurité du site via des outils officiels comme Google Safe Browsing.

Preuve de sécurité : Utiliser des services comme URLVoid pour prouver que le site n'est pas sur liste noire et ne contient aucun malware.

Conclusion

La sécurité informatique est un processus continu. Elle nécessite une veille constante pour anticiper les menaces, des tests techniques rigoureux pour valider la solidité des accès (mots de passe complexes obligatoires), et une communication claire pour maintenir le lien de confiance avec les utilisateurs.